

Nmap lab

Version 1.1, 28-09-2020, by Ivo Nijhuis

Introduction



Nmap, retrieved on 28-10-2019 from nmap.org

In this lab we'll learn how to scan a network to discover available hosts and find out, what software they are running.

During this lab will use Nmap, a popular open source tool for network discovery and vulnerability scanning. Nmap is able to send different types of packets over the network. By carefully analyzing the responses it receives, it is able to find out what hosts are available in a network and what Operating System and other services are running on these hosts. This information can then be used by network administrators to find potential security risks.

Warning



Nmap is a powerful tool and like many network security tools, it can be used for good or for bad purposes. Only use Nmap on networks when you are the owner of the network, or when you have permission to do so. Network administrators usually do not like it, if unauthorized people run Nmap on their networks. They do have ways to track you down or block you from the network entirely.

Do NOT run Nmap on a network without first obtaining permission.

Do NOT run Nmap on Eduroam. (You have been warned.)

DO try Nmap on your home network, or try Nmap on a closed-off network, set up specifically for this purpose.

Installation

Before you begin, you should have:

- VirtualBox installed on your laptop (You probably still have this, from when we set it up during the Infrastructure course. If not: download and install again.)
- Downloaded the Virtual Machine `HvA-NE1-Debian.ova` from the course materials on DLO

Now, load the downloaded VM into VirtualBox. To get this done, start VirtualBox and from the menu choose `File` and `Import Appliance`. This will give you a wizard from which you'll have to choose the downloaded `.ova` file. Click `Continue` and then `Import`.

Under `Settings`, check the `Network` settings for your VM. It should be set to `Network Bridge Adapter`.

Finally, you'll need the account information: you can login to your VMs using `student / HvA_student` or `root / HvA_root`.

Connect to the network

As we said before, it is a bad idea to run Nmap on a network without permission. There are two different ways that you can participate in this lab:

1. When doing this lab in the classroom, your teacher will provide an isolated wireless network that you can freely use for testing. Connect your laptop to the following network:

SSID: NE1spot

Password: raadjenooit

Also connect your cellphone to this network, so that we'll have different devices to discover!

2. You can also make this lab from home. In this case, you'll scan your own home network.

Scanning the network

First, we need to know what IP-addresses are available on the network. Check your IP address inside your Virtual Machine and also check your IP-address directly on your own laptop or cellphone.

What is the IP-address for each of your connected devices? What is the subnet mask? What is the IP-address for the WiFi access point (your default gateway)?

My laptop IP: 192.168.178.10 (213.127.91.125 - public)
My phone IP: 192.168.178.11
My VM IP: 10.0.2.15
Subnet mask: 255.255.255.0
Default gateway: 10.0.2.2 (VM) - 192.168.178.1 (laptop)

When doing the lab in the classroom, you should have an IP address like: 10.0.0.x/24 and the default gateway is probably 10.0.0.1. When working from home, your IP address could be something like 10.x.y.z/8 or 192.168.x.y/16.

Remember these IP addresses, because those are a few interesting machines to scan later!

With this information, we are now ready to scan the network for available hosts. Enter the command below. When working from home, use your own network ID and subnet mask instead of 10.0.0.1/24. Make sure you're using a private IP address!

```
sudo nmap -sn -n -PS 10.0.0.1/24
```



This should return a list of available hosts. Are your own machines in this list? Make a screenshot or picture of your results to hand in.



Remember: if any scan shows too much output to fit the screen, you can always use Linux output redirection. Use `nmap | more` to see the results per page or `nmap > filename` to store the results in a file.

What just happened?

- First of all, we run `nmap` as root. While you can run `nmap` as a normal user, it's functionality is quite limited. As root, you have direct access to various network protocols, so `nmap` can send 'customised' packets for more detailed results.
- `-sn` tells `nmap` to just scan for hosts and not do a full port scan for each host. We'll get to that later!
- `-n` tells `nmap` to skip reverse DNS resolution for the IP addresses it finds. This saves a lot of time, speeding up the scan (not to mention that our test network does not come with a connected DNS server.)
- `-PS` tells `nmap` to find hosts by sending TCP SYN packets and listen for responses. There are other options you could try.
- Finally, `10.0.0.1/24` specifies the network range to scan

Scanning the Operating System

From your list of hosts, pick a few IP-addresses to scan in more detail. We'll now use `Nmap` to try to determine the target's Operating System. The scan also lists which ports are open on the target system. Enter:

```
sudo nmap -O target-ip-address
```



Run this scan for your own laptop, Virtual Machine and smartphone, using the IP addresses you looked up earlier. Make screenshots or pictures of your results to hand in. Are the results accurate?



Now repeat this scan for a couple of other IP addresses. Make sure to find a few examples of different (desktop and mobile) operating systems. Make screenshots or pictures of your results to hand in.

Port scan

Our next move will be a port scan. We will send packets to all ports that may be open on a target system. Depending on the responses that are received, we can learn a lot about the target system: what OS version could it be running, what services are available, what software versions are installed? If an attacker knows a vulnerability or exploitable bug for any of this software, the next step could be to compromise or take over the target system. Enter:

```
sudo nmap -A target-ip-address
```



Run this scan for a couple of different target systems. What are some of the services that you can find, running on the hosts? Do any hosts seem to be protected by a firewall? Make screenshots or pictures of your results to hand in.

To find out more about service/daemon versions being used, try:

```
sudo nmap -sV target-ip-address
```



Run this scan for a couple of promising target systems. What are some of the software versions that you can find? Make screenshots or pictures of your results to hand in.

Vulnerability detection

As a final exercise, we'll have Nmap run a script that checks for known security vulnerabilities:

```
sudo nmap -Pn --script vuln target-ip-address
```



Run this scan for a couple of different target systems and see if you find any warnings. Your Virtual Machine will certainly show some, so scan it as well. Make screenshots or pictures of your results to hand in.

Complete the lab

To wrap up the lab, make a single document containing the screenshots or pictures you took of the results of the various scans. Make sure your name and class are clearly mentioned on top. Upload your document to DLO.

Next steps...

When you want to explore further, you can try out some of the commands in this lab on your home network and see what shows up!

An Internet server that is set up specifically to be scanned using Nmap is available at scanme.nmap.org. You are authorized to scan this machine with Nmap or other port scanners. Try not to hammer on the server too hard. A few scans in a day is fine, but don't scan 100 times a day.

You can also check the following sources for more information:

- A quick introduction to the most important Nmap commands on: <https://securitytrails.com/blog/top-15-nmap-commands-to-scan-remote-hosts>
- Download Nmap for different Operating Systems and read the full documentation on <https://nmap.org/>